

HRMS

User Roles & Access Flow

Document for client review

Generated: June 16, 2026

1. System Overview

HRMS access is controlled by **two main layers**:

Layer	Mechanism	What it controls
Primary role	<code>users.role_users_id</code> → roles table	Login redirect, admin routes, company data scope
Fine-grained access	Spatie permissions	Sidebar menus, create/edit/delete actions, reports
Organizational scope	Team / Location / Department	Which employees a user can see and approve leave for

2. Built-in Roles

Role ID	Name	Description
1	admin	Super Admin — full system access
2	employee	HR / Staff — permissions assigned by admin
3	client	Regular employees OR external clients (see note below)

Important: Role ID 3 is used for two different user types in the system: (1) regular employees who have a record in the `employees` table, and (2) external clients who have a record in the `clients` table but no employee record.

3. Custom Roles (ID 4 and above)

- Created by admin under **Settings** → **Roles and Access**
- Each custom role can be assigned specific permissions

- Built-in roles (admin, employee, client) cannot be deleted
- When admin adds an employee manually, role 3 is excluded from the role dropdown
- Public self-registration assigns role 3 by default

4. Login Flow

```

User enters Username + Password
↓
Laravel authenticates credentials
↓
role_users_id = 1 → Redirect to /admin/dashboard
role_users_id = 3 → Redirect to /employee/dashboard
role_users_id = 2 or other → Redirect to /employee/dashboard

```

Login status fields

Field	Table	Used at login?	Purpose
is_active	users, employees	No	Marks account active/inactive in admin screens and reports
status_id	employees only	No	HR employment status label (e.g. Active, Probation)

Currently, login only checks **username and password**. Inactive users are not automatically blocked at login.

5. Route Protection

Middleware	Rule
auth	User must be logged in
admin	Only role_users_id = 1 can access /admin/* routes
secure.app	Authenticated requests; extra origin check on form submissions

6. How Users Are Created

Method	Default Role	Account Status	Result
Admin adds employee	2 or custom role	Active (is_active = 1)	User + Employee records
Admin adds client	3 (client)	Active	User + Client records
Admin adds system user	1 (admin)	From form	User record only
Public registration form	3 (default)	Always active	User + Employee records
Bulk import	2	Active	User + Employee records

7. Access by Role Type

7.1 Admin (Role ID = 1)

- Dashboard: /admin/dashboard
- Can see all companies and system-wide data
- Full access to admin routes
- Typically has all module permissions

7.2 HR / Staff (Role ID = 2 or custom with permissions)

- Dashboard: /employee/dashboard
- Limited to their own company data
- Can access only modules granted via permissions (employees, attendance, leave, payroll, etc.)

7.3 Regular Employee (Role ID = 3 + employee record)

- Dashboard: /employee/dashboard
- Self-service: profile, attendance, leave/WFH requests
- May get extra access if assigned as team lead or location head
- Public registration users fall in this category

7.4 External Client (Role ID = 3 + client record, no employee)

- Dashboard: /client/dashboard
- Access: Projects, Tasks, Invoices
- Separate client portal layout

8. Leadership Access (without full HR permissions)

Position	Source	Extra capabilities
Team Department Head / Project Manager / Assistant HR	Teams module	View team members; approve team leave/WFH
Location Head	Location heads assignment	My Locations page; manage location employees; approve leave; bulk attendance type
Department Head	Department settings	Approve leave/WFH for department employees
Team Member	Team membership	My Team page

9. Data Scoping Logic

```
Logged-in user
├── Admin (role 1)? → See all companies and all data
└── Non-admin → Limited to own company (from employee record)
    ├── Team lead or Location head (without full employee permission)?
    │   └── → See only their team / location members
    └── Otherwise → Access based on assigned Spatie permissions within company
```

10. Main Modules (Permission-based)

Module	Who typically has access
Users & Assign Role	Admin / HR with user permissions
Employees	HR with employee permissions
Organization (Company, Department, Location, Team)	Admin / HR
Core HR (Promotion, Award, Travel, Termination, etc.)	HR
Timesheet & Attendance	HR; employees for own attendance
Leave / WFH Management	HR, department heads, team leads, location heads
Payroll	HR / Payroll officer
Performance, Recruitment, Training	HR (permission-based)
Reports	Admin / HR (permission-based)
Client Portal (Projects, Invoices)	External clients only

11. Quick Reference

User Type	Role ID	Employee Record	Client Record	Main Dashboard
Super Admin	1	Optional	No	/admin/dashboard
HR Manager	2	Yes	No	/employee/dashboard

Regular Employee	3	Yes	No	/employee/dashboard
External Client	3	No	Yes	/client/dashboard
Team / Location Lead	Any	Yes	No	/employee/dashboard + scoped tools

12. API Login

Mobile/API login validates username and password only. It returns a Sanctum token. `is_active` and `status_id` are not checked at API login.
